Sécurité des systèmes informatiques

Les techniques d'attaque sur les systèmes informatiques

Abdeltouab Belbekkouche

a.belbekkouche@umontreal.ca

Université de Montréal

Contenu

- Attaques de mot de passe
- Usurpation d'adresse IP
- Attaques par déni de service
- Attaques « homme au milieu »
- Attaques par débordement de tampon
- Attaques biométriques
- Attaques par ingénierie sociale

Attaques de mot de passe

- **Identifiant / mot de passe**
  - Moyen de connexion à un système informatique
- Bloquer temporairement le compte d'un utilisateur après un certain nombre de tentatives non réussies ➔ difficile de s'infiltrer dans de tels systèmes de cette manière
- Bloquer l'ensemble des comptes utilisateurs ➔ **Déni de service**
- Moyen permettant au pirate d'obtenir les mots de passe
  - Keylogger
  - Ingénierie sociale
  - Espionnage
  - Etc.

Attaques de mot de passe (suite)

- Suite à une intrusion à un premier compte utilisateur, si le pirate réussi à obtenir le fichier chiffré des mots de passe
  - Attaque par force brute
  - Attaque par dictionnaire
  - Attaque hybride
- Utilisation du calcul distribué
  - Puissance des … cartes graphiques
  - ~1 000 000 000 mots de passes / seconde (supercalculateur d'une université par exemple)
  - 392 262 404 189 mots de passe / seconde (distributed.net: projet RC5 72)
    - 92 000 participants
  - Informatique en nuage (*cloud computing*)

Choix de mot de passe

- Plus un mot de passe est simple, plus il est facile de le casser
  - 4 chiffres ➔ 10 000 possibilités (10^4)
  - 4 lettres ➔ 456 972 possibilités (26^4)
  - Chiffres, lettres (minuscules et majuscules) et caractères spéciaux …
- Politique de sécurité en matière de mots de passe
  - Une longueur minimale
  - La présence de caractères particuliers
  - Un changement de casse (minuscule et majuscule)
  - Durée d'expiration des mots de passe
  - Utiliser des logiciels de cassage de mots de passe en interne ⚠

Choix de mot de passe (suite)

- Mots de passe à éviter
  - Votre identifiant
  - Votre nom
  - Le nom d'un proche
  - Un mot du dictionnaire
  - Un mot à l'envers
  - Un mot suivi d'un chiffre

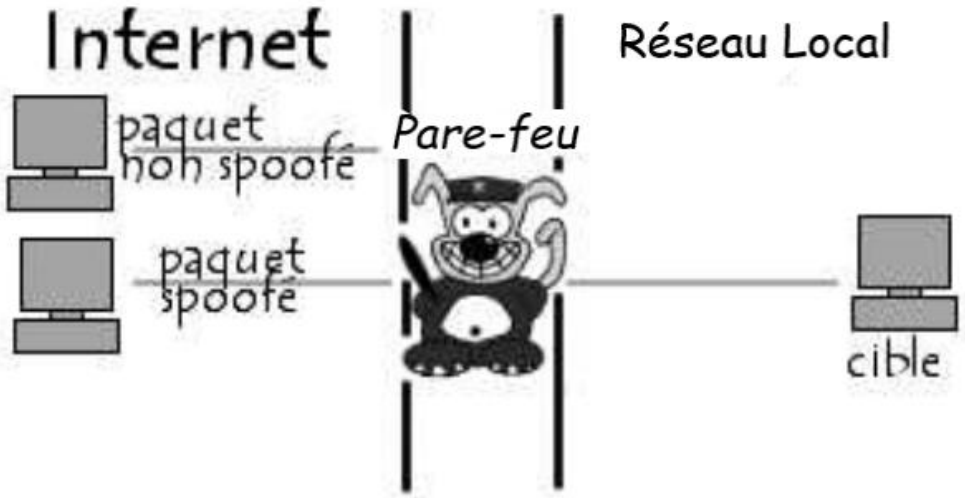
En 2025 …

Rank	Password
1	123456
2	12345678
3	123456789
4	admin
5	1234
6	Aa123456
7	12345
8	password
9	123
10	1234567890
11	12345678910
12	1234567
13	Aa@123456
14	Pass@123
15	Password
16	123123
17	P@ssw0rd
18	111111
19	admin123
20	1111

Source: https://www.comparitech.com/news/minecraft-qwerty-and-india123-among-2025s-most-common-passwords-report/

Usurpation d'adresse IP

- *IP spoofing*
- Remplacer l'adresse IP de l'expéditeur d'un paquet IP par l'adresse IP d'une autre machine
- Permet à un pirate d'envoyer des paquets de façon anonyme
- **But:** faire passer des paquets sur un réseau sans que ceux-ci ne soient interceptés par le système de filtrage de paquets (pare-feu)



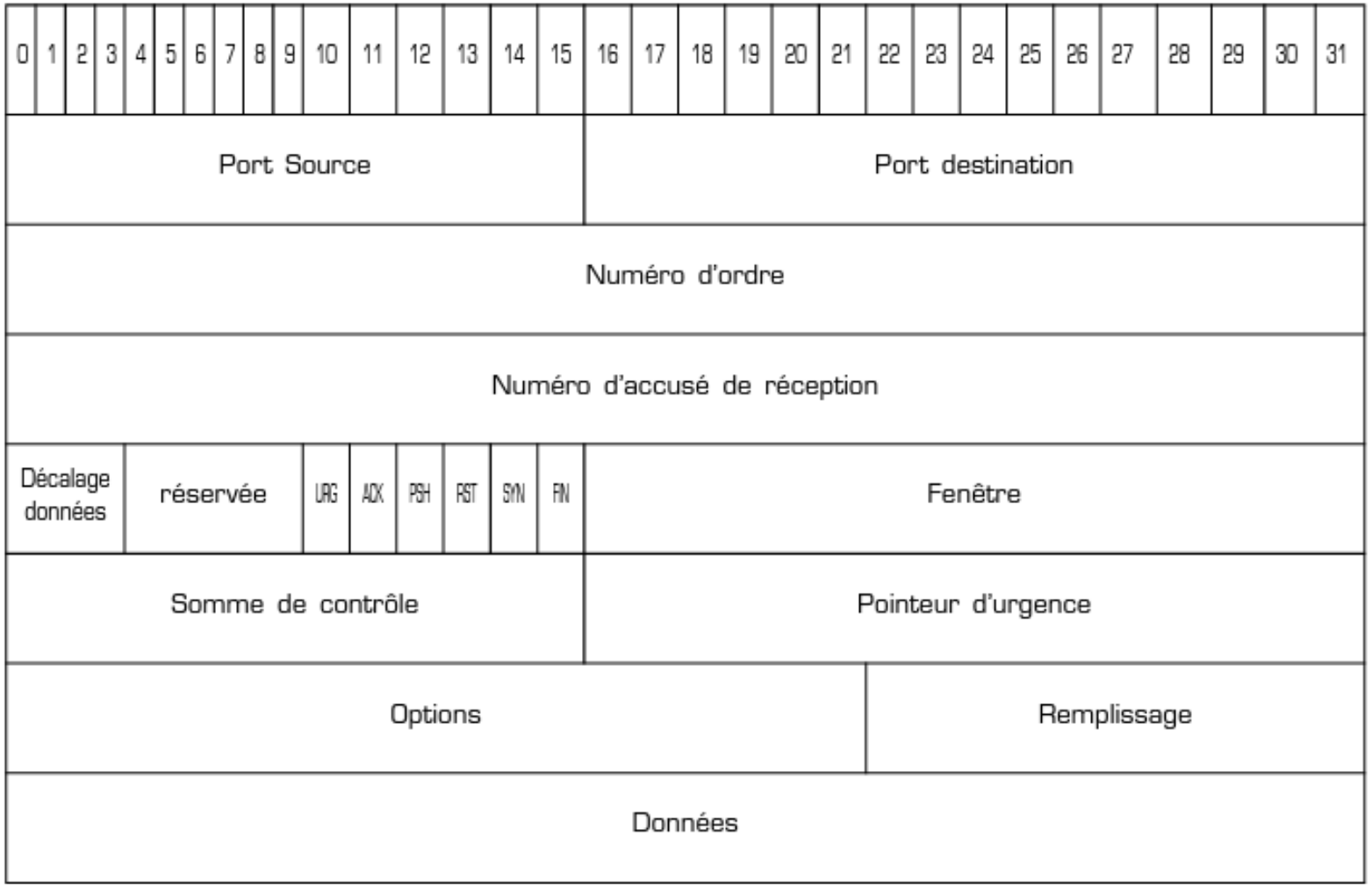
Usurpation d'adresse IP (suite)

- Modification de l'en-tête du datagramme IP

<table>
<tr><td>Version</td><td>Longueur d'en-tête</td><td>Type de service</td><td colspan="2">Longueur totale</td></tr>
<tr><td colspan="3">Identification</td><td>Drapeau</td><td>Décalage fragment</td></tr>
<tr><td colspan="2">Durée de vie</td><td>Protocole</td><td colspan="2">Somme de contrôle en-tête</td></tr>
<tr><td colspan="5">Adresse IP source</td></tr>
<tr><td colspan="5">Adresse IP destination</td></tr>
<tr><td colspan="5">Données</td></tr>
</table>

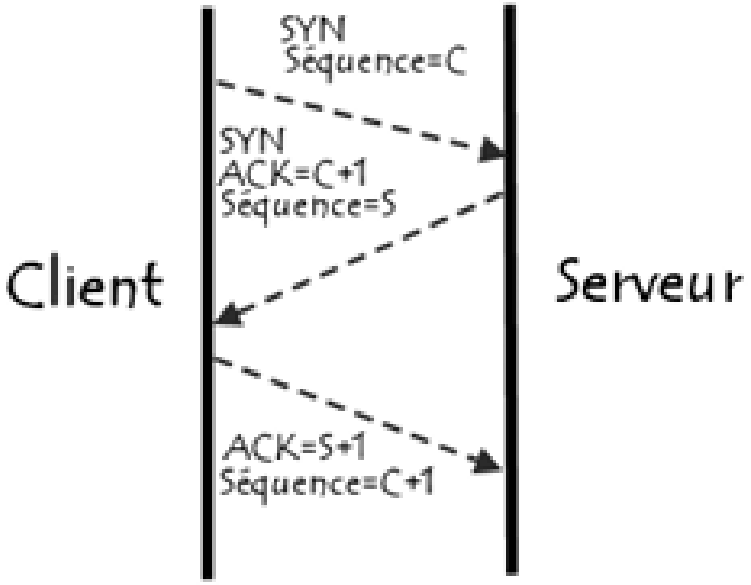
Usurpation d'adresse IP (suite)

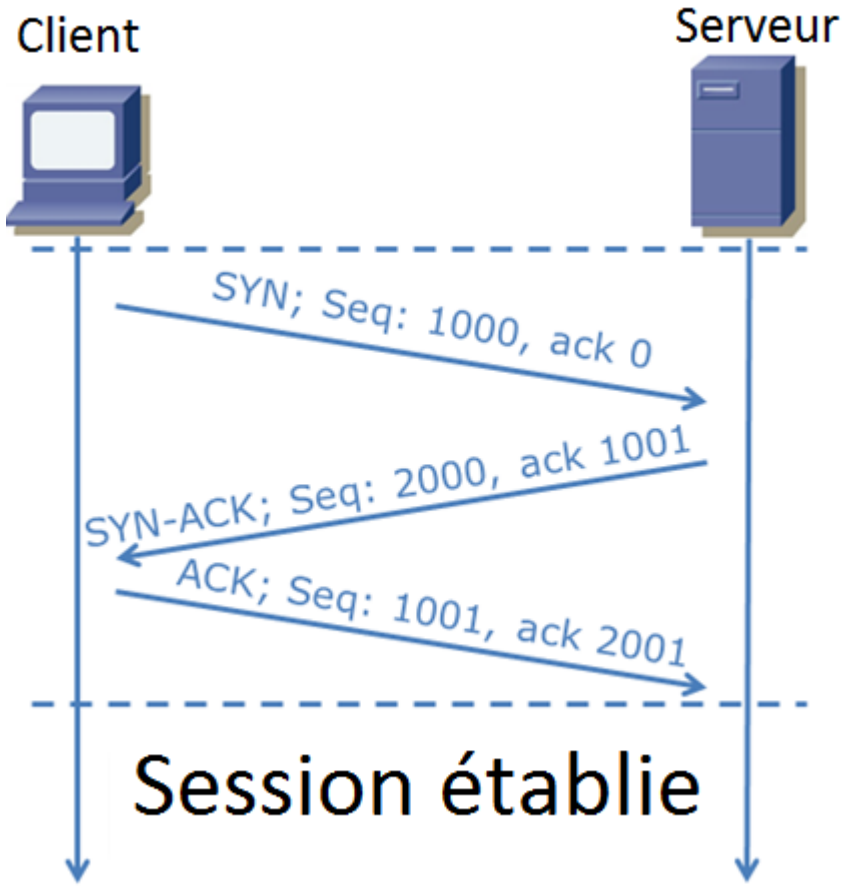
- Les datagrammes IP encapsulent des segments TCP
  - Numéro d'ordre
  - Drapeaux
    - SYN
    - ACK
    - FIN
    - RST
    - Etc.
  - Etc.



Usurpation d'adresse IP (suite)

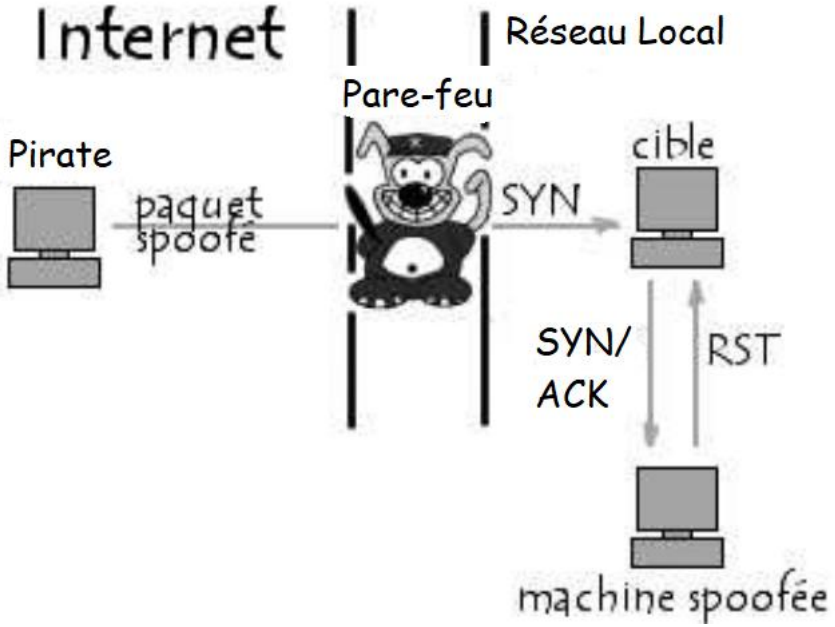
- Les trois étapes pour établir une connexion TCP (*three-way handshake*)
  - Le client envoie un paquet **SYN** au serveur
  - Le serveur répond par un paquet **SYN-ACK**
  - Le client répond par un paquet **ACK**

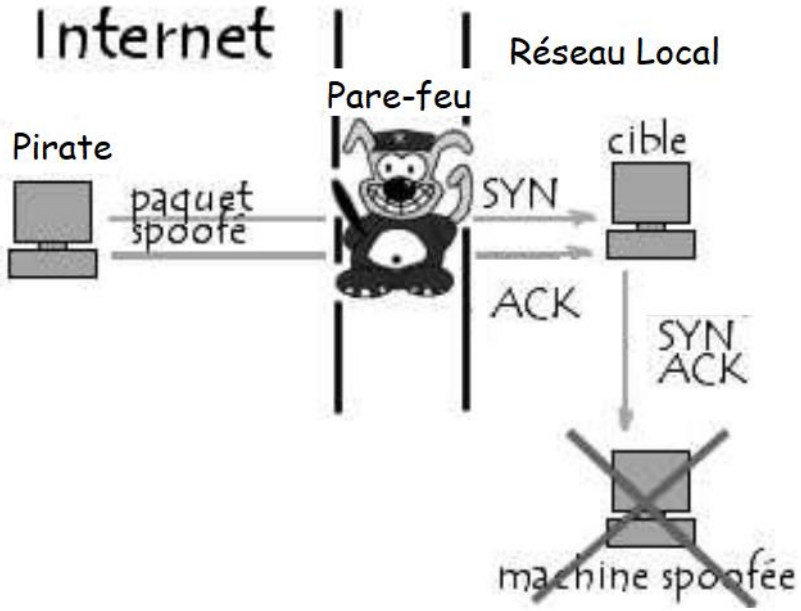




Usurpation d'adresse IP (suite)

- **La machine usurpée va répondre par un paquet RST**
  - **Ce qui mettra fin à la connexion**
  - Attaque à l'aveugle (*blind attack*)
- Le travail du pirate consiste à invalider la machine usurpée
  - c.-à-d., la rendre injoignable durant toute la durée de l'attaque
- Prédiction des numéros de séquence émis par la cible
- *Source routing*
  - Indiquer une route de retour spécifique pour les paquets
- Le pirate envoie des accusés de réception à la cible pour maintenir la communication



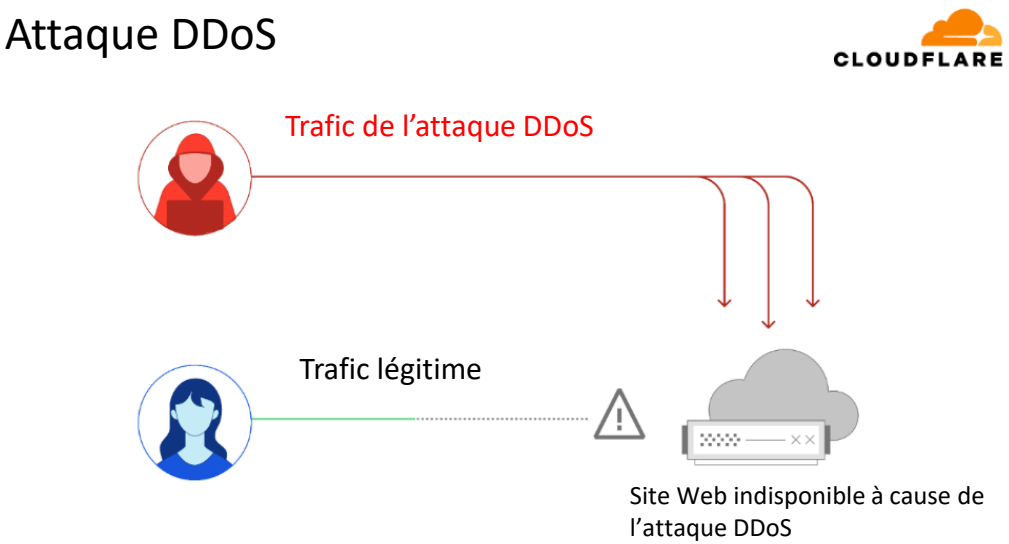


Attaques par déni de service

- *Denial of Service* (DoS)
- **But:** rendre indisponible pendant un temps indéterminé les services ou les ressources d'une organisation
- Nuire à la réputation et/ou au bon fonctionnement d'organisations ayant une présence sur Internet
- La plupart des attaques **DoS** exploitent des failles liées à l'implémentation d'un protocole de la pile TCP/IP

Attaques par déni de service (suite)

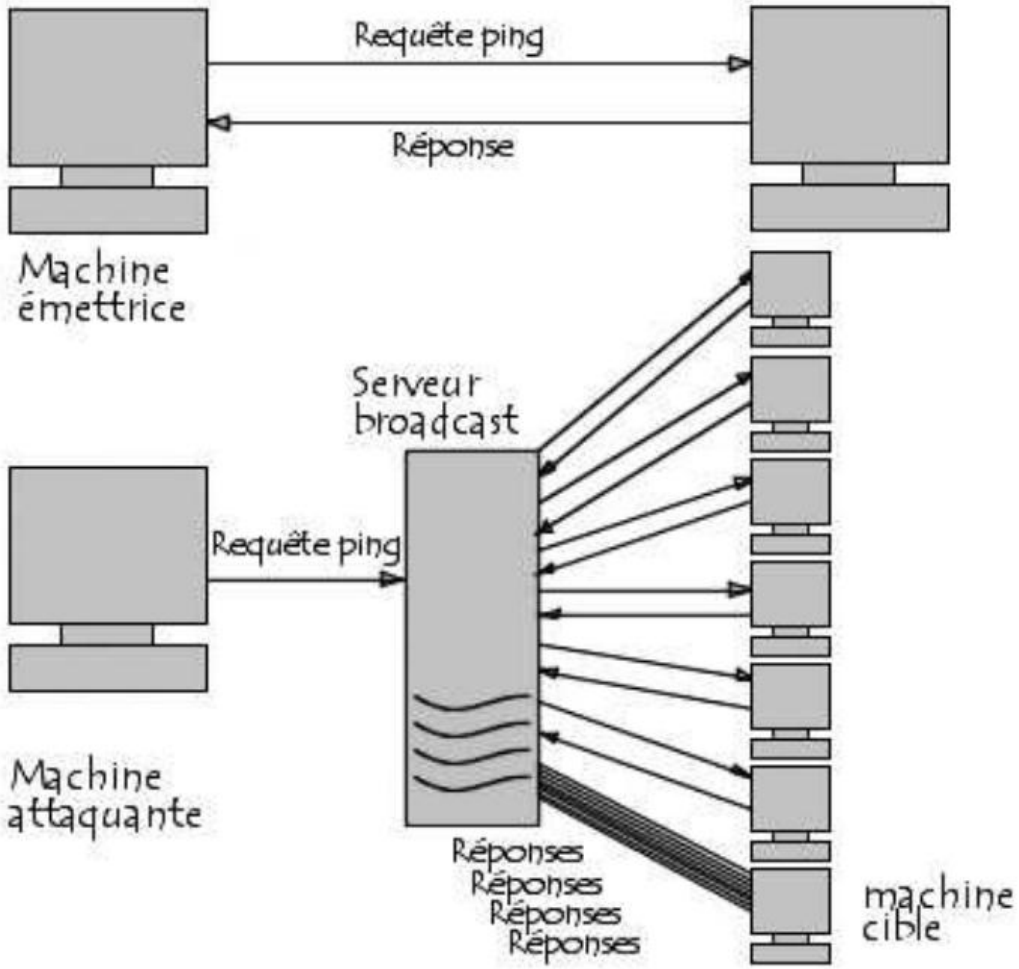
- Deux types
  - **Déni de service par saturation**
    - Submerger une machine de requêtes
  - **Déni de de service par exploitation de vulnérabilité**
    - Exploiter une faille du système cible
- Déni de service distribué (*Distributed Denial of Service:* ***DDoS***)
  - Lorsque provoqué par plusieurs machines



Attaques par déni de service (suite)

- Attaque par réflexion
  - *Smurf*
  - Trouver une liste de serveurs de diffusion
  - Falsifier l'adresse IP source du message **ping**

- Attaque par amplification
  - Utiliser des serveurs dont la réponse à une requête renvoie bien plus de données que la requête originale
  - Network Time Protocol (NTP) ➔ la réponse est environ 200 fois la taille du paquet original
  - Protocoles DNS et SMTP ➔ taux d'amplification allant jusqu'à 650 fois le flux original

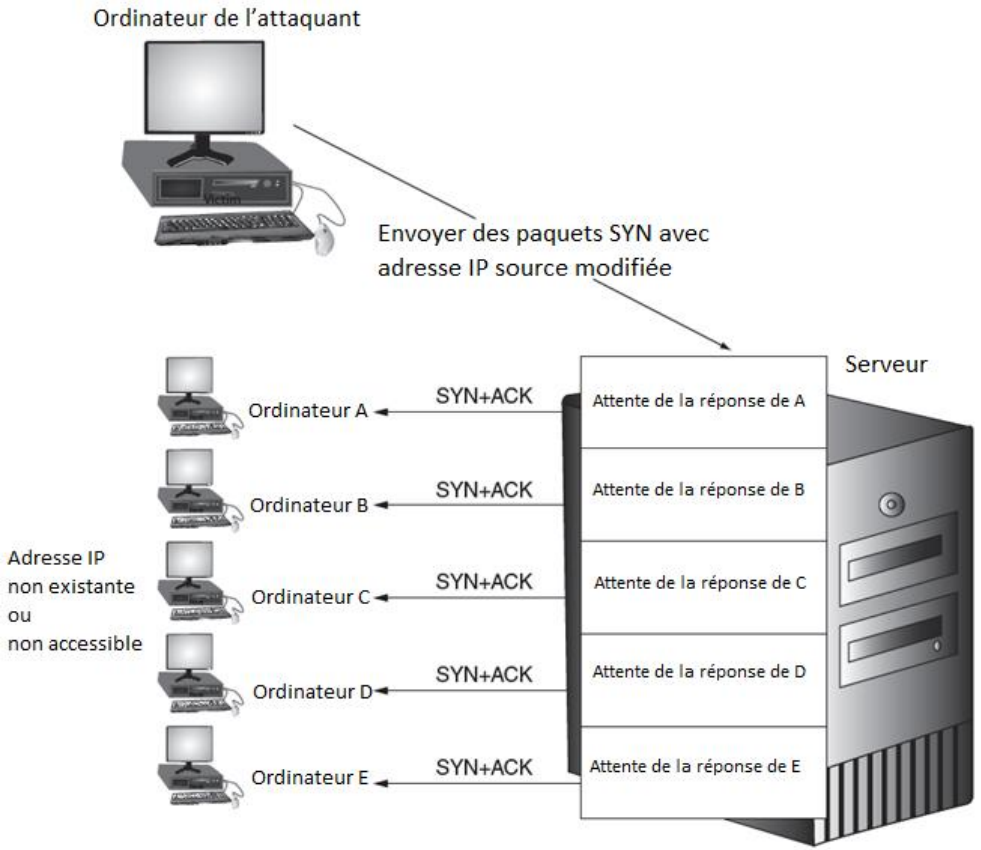


Attaques par déni de service (suite)

- **Attaque du ping de la mort**
  - *Ping of death*
  - Créer un paquet IP dont la taille totale excède la taille maximum autorisée (65 536 octets)
  - Repose sur les vulnérabilités des vieilles implémentations des protocoles TCP/IP ✓
- **Attaque par fragmentation**
  - *Fragment attack*
  - Exploite le principe de fragmentation du protocole IP
    - Fragmenter les paquets de taille importante en plusieurs paquets IP possédant tous un numéro de séquence et un numéro d'identification commun
    - À la réception, le destinataire réassemble les paquets grâce aux valeurs de décalage (*offset*) qu'ils contiennent
  - Insérer dans des paquets fragmentés des informations de décalage erronées
  - Les vides et les recoupements (*overlappings*) peuvent provoquer une instabilité du système
  - Les systèmes récents ne sont plus vulnérable à cette attaque ✓

Attaques par déni de service (suite)

- Attaque SYN
  - *TCP SYN Flooding*
  - Envoyer un grand nombre de requêtes SYN à une machine avec une adresse IP source inexistante ou invalide
  - La machine cible met en file d'attente (dans une structure de données en mémoire) les connexions « à moitié » ouvertes
  - Attend de recevoir les ACKs correspondants
  - Un mécanisme d'expiration des connexions « à moitié » ouvertes après un certain délai existe mais il peut ne pas suffire
  - Plantage ou redémarrage des systèmes vulnérables



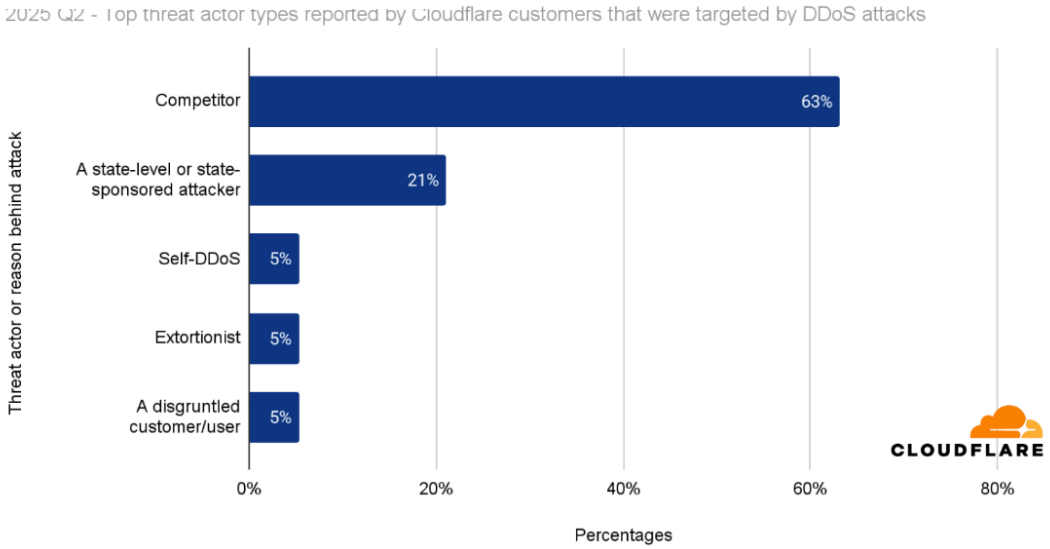
Attaques par déni de service (suite)

- **Attaque par requêtes élaborées**
  - Envoyer en masse des requêtes légitimes à la couche applicative
  - Rendre inaccessible un site Web ou un service en lui faisant traiter des demandes qui sollicitent beaucoup de ressources (base de données par exemple)
  - Requiert une analyse fine de la cible
    - Pages HTML qui ne sont pas en cache
    - Pages qui requièrent beaucoup de données
    - Pages qui créent des erreurs sur le serveur
    - Module du site Web connu pour une faille particulière
    - Etc.
- **Parades**
  - Veille active sur les nouvelles attaques et vulnérabilités
  - Appliquer les correctifs (*patchs*) et les mises à jour logicielsC

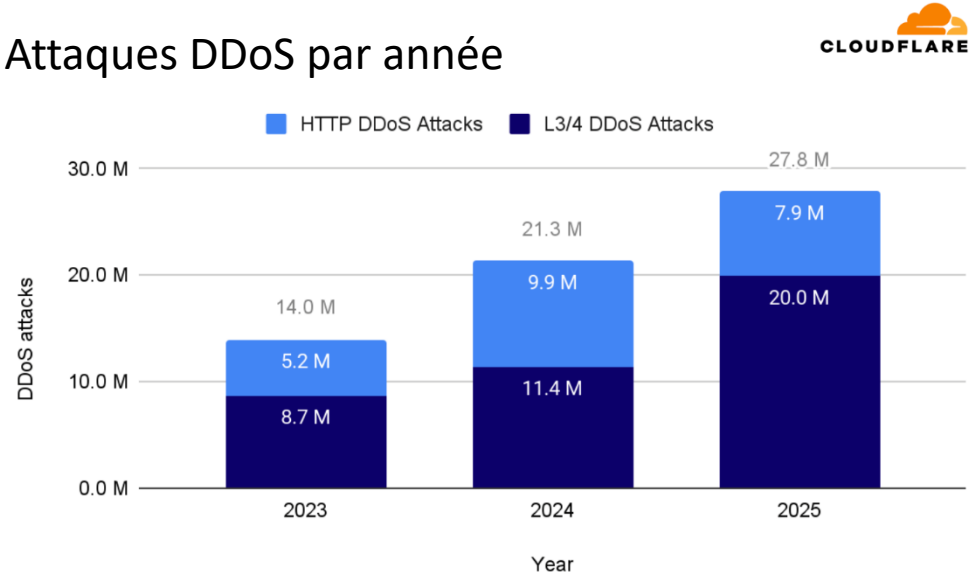
Attaques par déni de service (suite) - Réalité des attaques

- Attaque de pointe (2025, 2ième trimestre):
  - **Intensité:** 7.3 térabits par seconde (Tbps) et 4.8 milliards de paquets par seconde
  - **Durée:** 45 secondes

Origine des attaques



Attaques DDoS par année



Source: https://blog.cloudflare.com/ddos-threat-report-for-2025-q2/

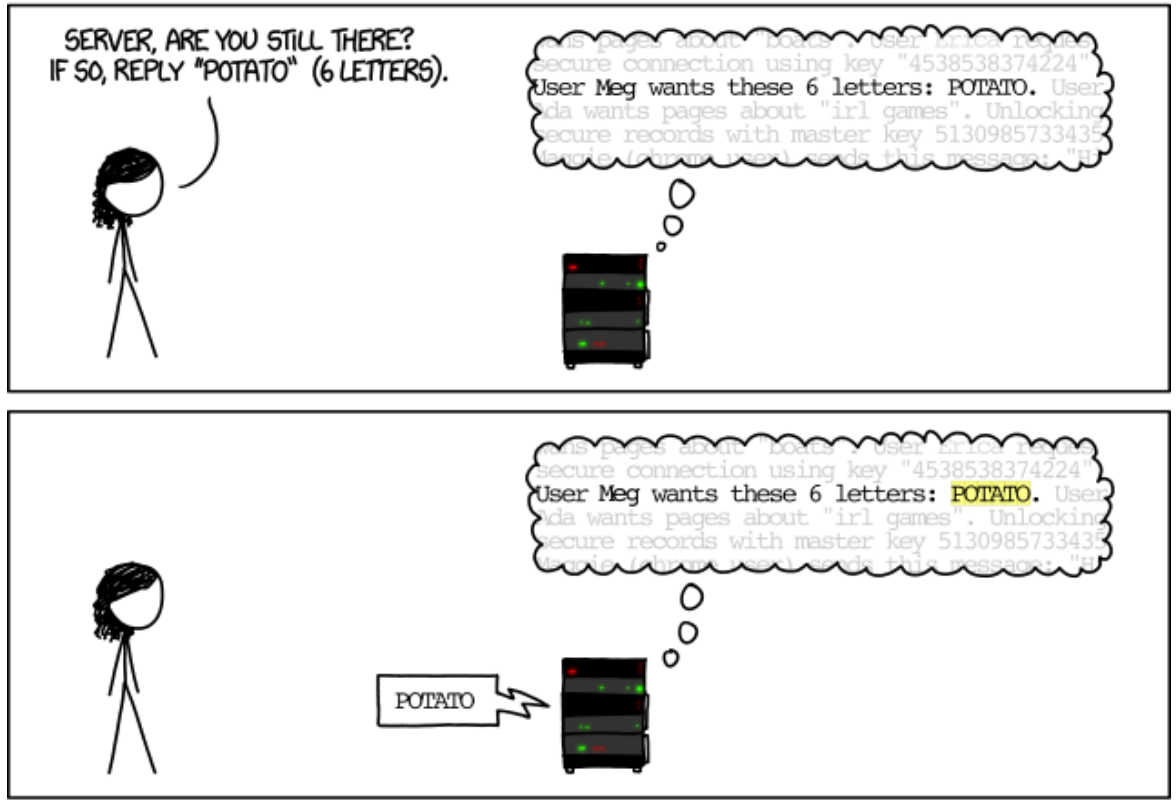
Attaques des failles TLS/SSL

- **(2009)** dissymétrie de charge entre le client et le serveur (~1:15)
  - Le client envoie de nombreuses demandes de renégociation des paramètres de sécurité
    - Générer une nouvelle clé de chiffrement pour la connexion en cours
    - Grande consommation des ressources sur le serveur Web
  - DDoS contre des cibles utilisant le protocole HTTPS
- **(2014)** Heartbleed
  - Implémentation OpenSSL (depuis 2012)
  - Traitement de mémoire incorrect pour les paquets du module de pulsation (*heartbeat*) du protocole TLS
  - Permet à un attaquant de lire la mémoire d'un serveur ou d'un client pour récupérer des informations confidentielles (clés privées p. ex.)

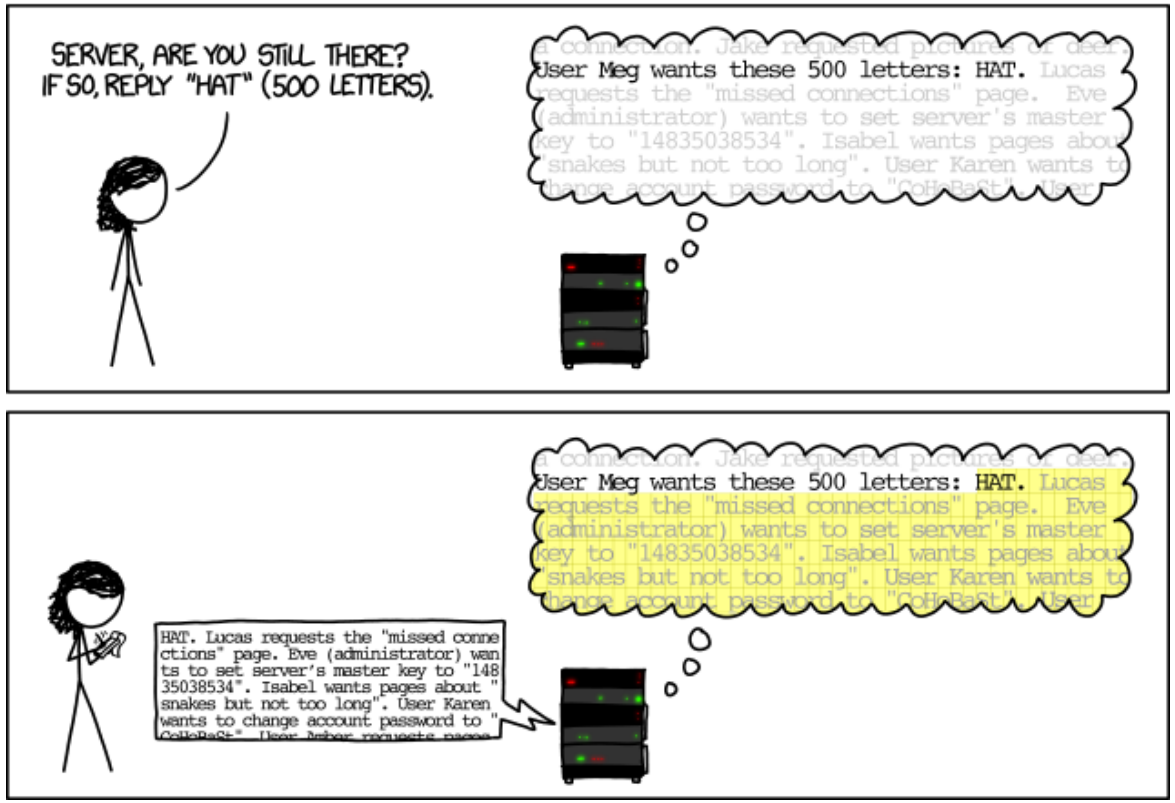
Attaques des failles TLS/SSL (suite)

- Heartbleed: comment ça marche?

Fonctionnement normal



Fonctionnement malicieux



Attaques « homme au milieu »

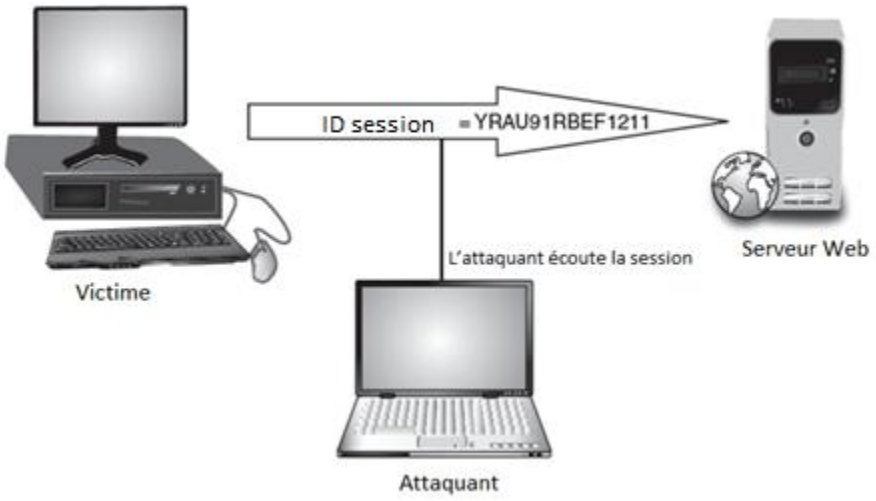
- Attaque de l'homme au milieu ou attaque de l'intercepteur
- *Man in the middle*
- Un pirate écoute une communication entre deux interlocuteurs et falsifie les échanges afin de se faire passer pour l'une des parties communicantes
- Écouter le réseau à l'aide d'outils d'écoute du réseau
  - Wireshark
  - tcpdump
  - Etc.

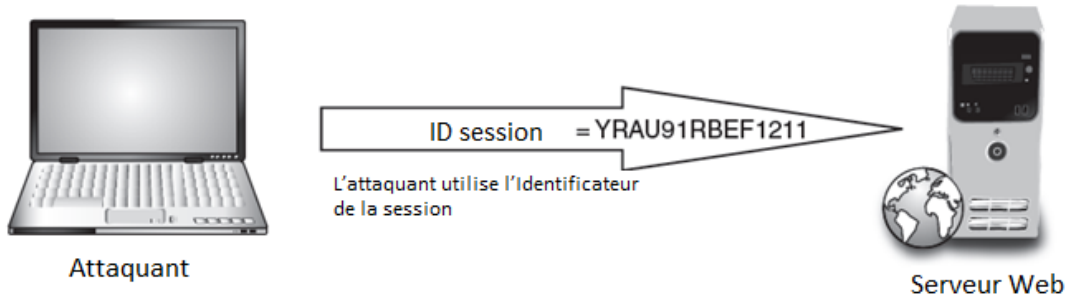
Attaques « homme au milieu » (suite)

- Attaque par rejeu (*replay attack*)
  - Intercepter des paquets de données et les **rejouer**
    - Les retransmettre tels quels au serveur destinataire (sans aucun déchiffrement)
  - Le pirate espère bénéficier des droits de l'utilisateur légitime
  - Exemple: envoyer un paquet qui contient un nom d'utilisateur et un mot de passe chiffrés à un serveur pour s'authentifier

Attaques « homme au milieu » (suite)

- Détournement de session TCP (*TCP session hijacking*)
  - Intercepter une session TCP initiée entre deux machines afin de la détourner
    - L'authentification s'effectue uniquement à l'ouverture de la session
  - Prédire les numéros de séquence (*source routing*)





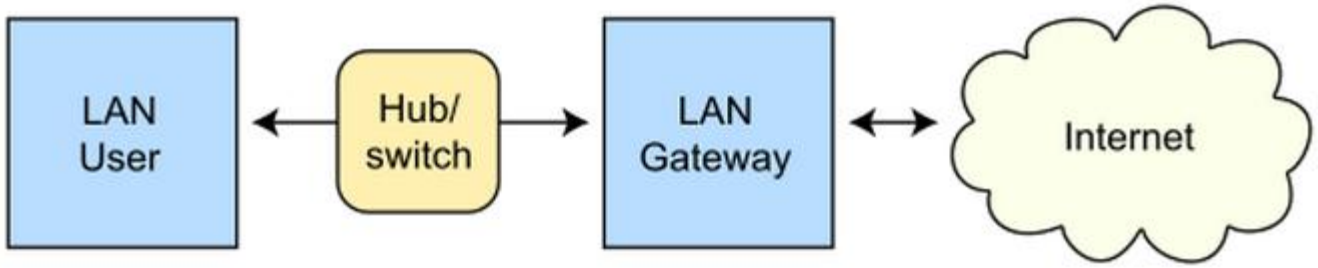
Attaques « homme au milieu » (suite)

- **Attaque du protocole ARP**
  - *Address Resolution Protocol* (ARP) permet de retrouver l'adresse IP d'une machine en connaissant son adresse physique (adresse MAC)
  - S'interposer entre deux machines locales en envoyant un paquet ARP **falsifié** indiquant que l'adresse MAC de l'autre machine a changé
    - L'adresse MAC fournie est celle de l'attaquant
  - Les deux machines cibles vont mettre à jour leur table dynamique appelée *cache ARP*
    - *ARP Cache poisoning*
    - *ARP spoofing*
    - *ARP redirect*

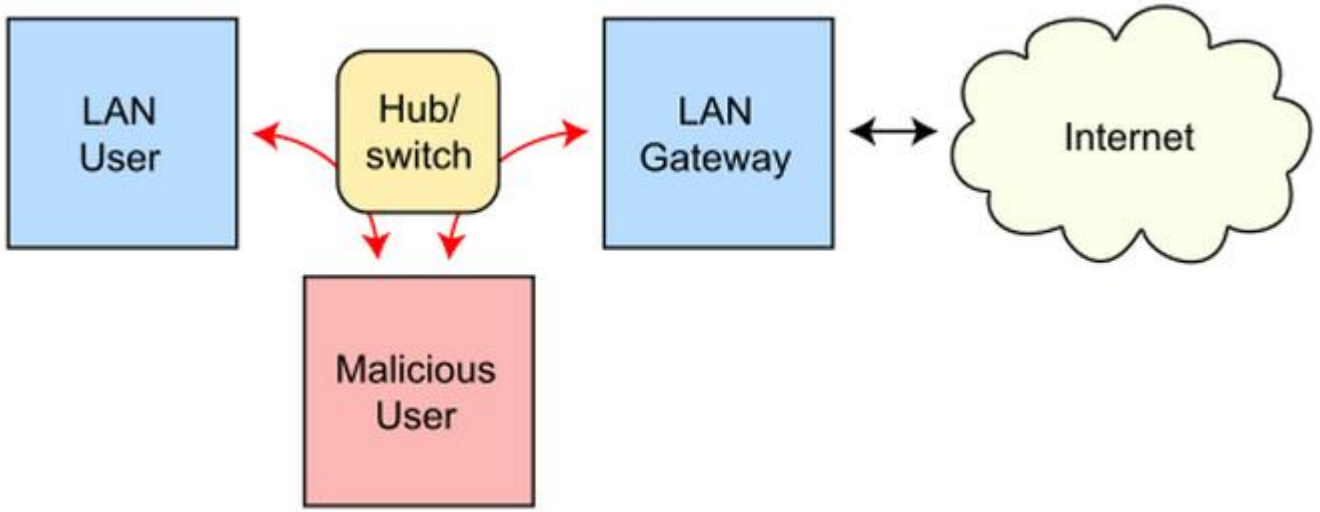
Attaques « homme au milieu » (suite)

- Attaque du protocole ARP (suite)

Fonctionnement normal

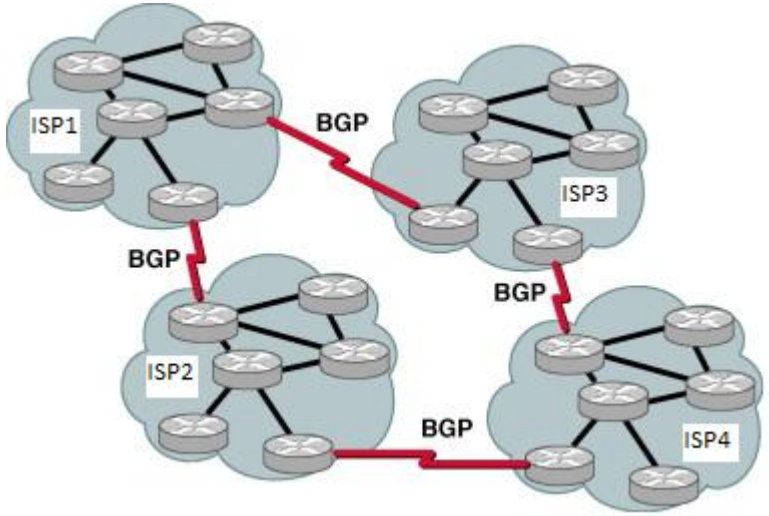


Fonctionnement avec attaque du protocole ARP



Attaques « homme au milieu » (suite)

- **Attaque du protocole BGP**
  - *Border Gateway Protocol*
  - Utilisé entre les routeurs des organisations qui structurent Internet
  - Quelle est la route la plus courte pour chaque paquet traversant Internet? ➔ Utilisation de **tables de routage**
  - Un pirate peut détourner le trafic Internet destiné à un site donné vers la machine de son choix
    - Introduire (ou prendre le contrôle) d'un routeur
    - Modifier sa table de routage
    - Cette modification sera reproduite et généralisée sur Internet
    - Exemple: cas de Pakistan Telecom et Youtube
  - **Parade:** *Secure BGP*

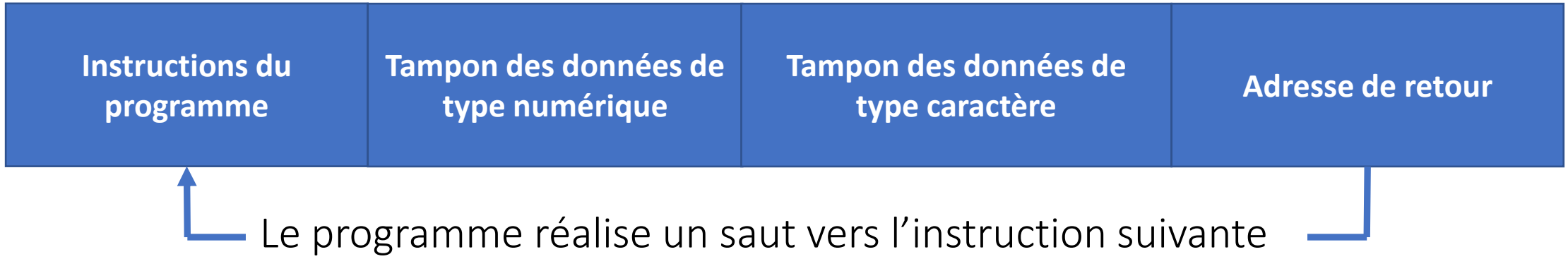


Attaques par débordement de tampon

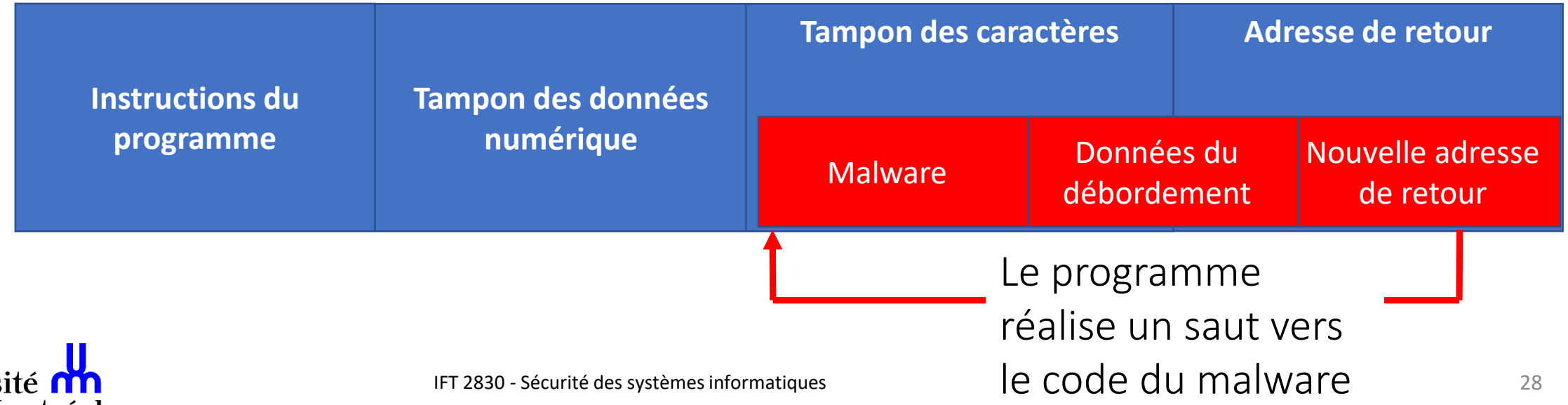
- *Buffer overflow*
- Exécution de code arbitraire par un programme en lui envoyant plus de données qu'il n'est censé en recevoir ➔ donner un accès au système
- Programmes acceptant des données en entrée (passées en paramètres)
- Exemple: la fonction `strcpy` du langage C
- **Parades**
  - Utilisation de langages à contexte d'exécution managé implémentant la vérification de bornes des tableaux (Exemple: le langage de programmation Java)
  - Bannir l'utilisation des fonctions dites « non protégées »: préférer `strncpy` à `strcpy` par exemple
  - Rendre la pile non exécutable
  - Etc.

Attaques par débordement de tampon (suite)

Traitement normal



Débordement de tampon

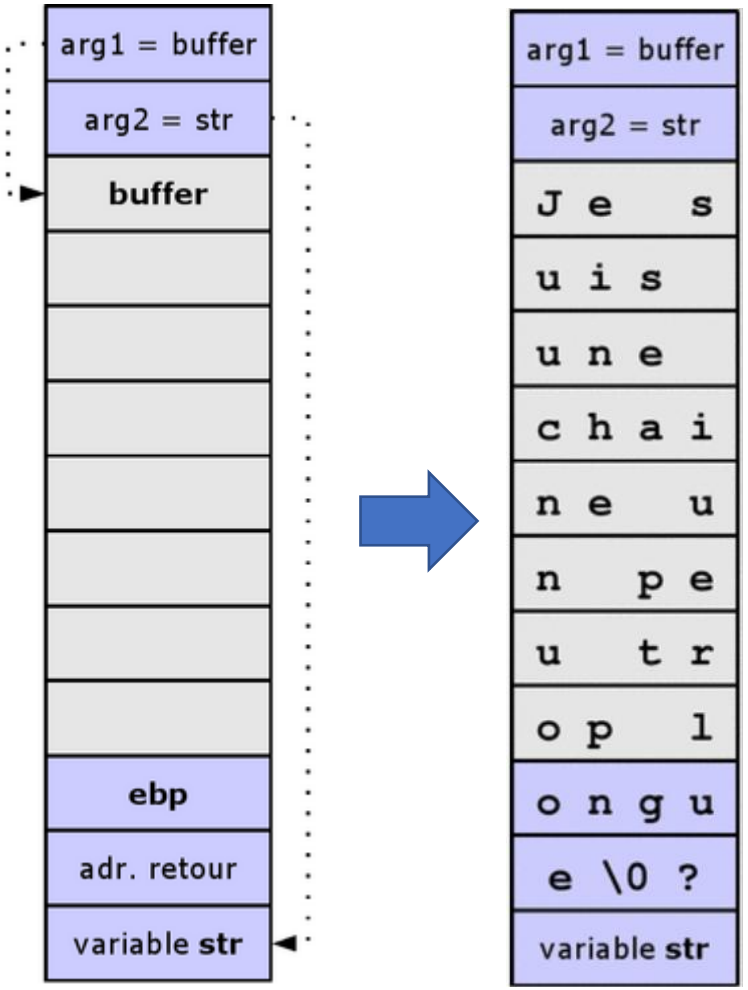


Attaques par débordement de tampon (suite)

- Cas de la fonction `strcpy`

```c
#include <stdio.h>
#include <string.h>

void foo(char *str)
{
  char buffer[32];
  strcpy(buffer, str);
  /* ... */
}
int main(int argc, char *argv[])
{
  if (argc > 1) {
    /* appel avec le premier argument de la ligne de commandes */
    foo(argv[1]);
  }
  /* ... */
  return 0;
}
```



Attaques biométriques

- L'identification biométrique est basée sur le principe de l'unicité de certains caractères d'un individu
  - Empreinte digitale
  - Reconnaissance faciale
  - Iris
  - Agencement des veines dans un doigt ou au fond de l'œil
  - ADN
  - Etc.
- Le matériel de sécurité biométrique peut faire l'objet d'attaques pour récupérer les droits d'accès d'un individu
- L'efficacité dépend fortement de la qualité du matériel

Attaques biométriques (suite)

- Empreintes digitales
  - Récupérer l'empreinte digitale laissée par un individu et la réutiliser
- Reconnaissance faciale
  - Il suffit de montrer une image de la personne pour tromper le système de reconnaissance
- **Parades**
  - Combiner plusieurs techniques biométriques
    - La reconnaissance de l'empreinte digitale avec la reconnaissance de la structure interne des veines du doigt par exemple
  - Mixer plusieurs systèmes d'indentification
    - Croiser l'identification biométrique avec d'autres techniques comme une carte à puce ou un mot de passe par exemple

Attaques par ingénierie sociale

- Collecter les informations directement des individus
  - Repose sur leur confiance
- Approches psychologiques
  - Persuasion (persuader la victime de fournir une information ou de prendre des actions)
  - Flatteries
  - Conformité
  - Amitié
- Réseaux sociaux
  - Collecter des informations personnelles sur les individus (noms, noms des proches, noms des amis, noms des employés d'une entreprise, etc.)
  - Trouver des mots de passe ou passer pour ces individus

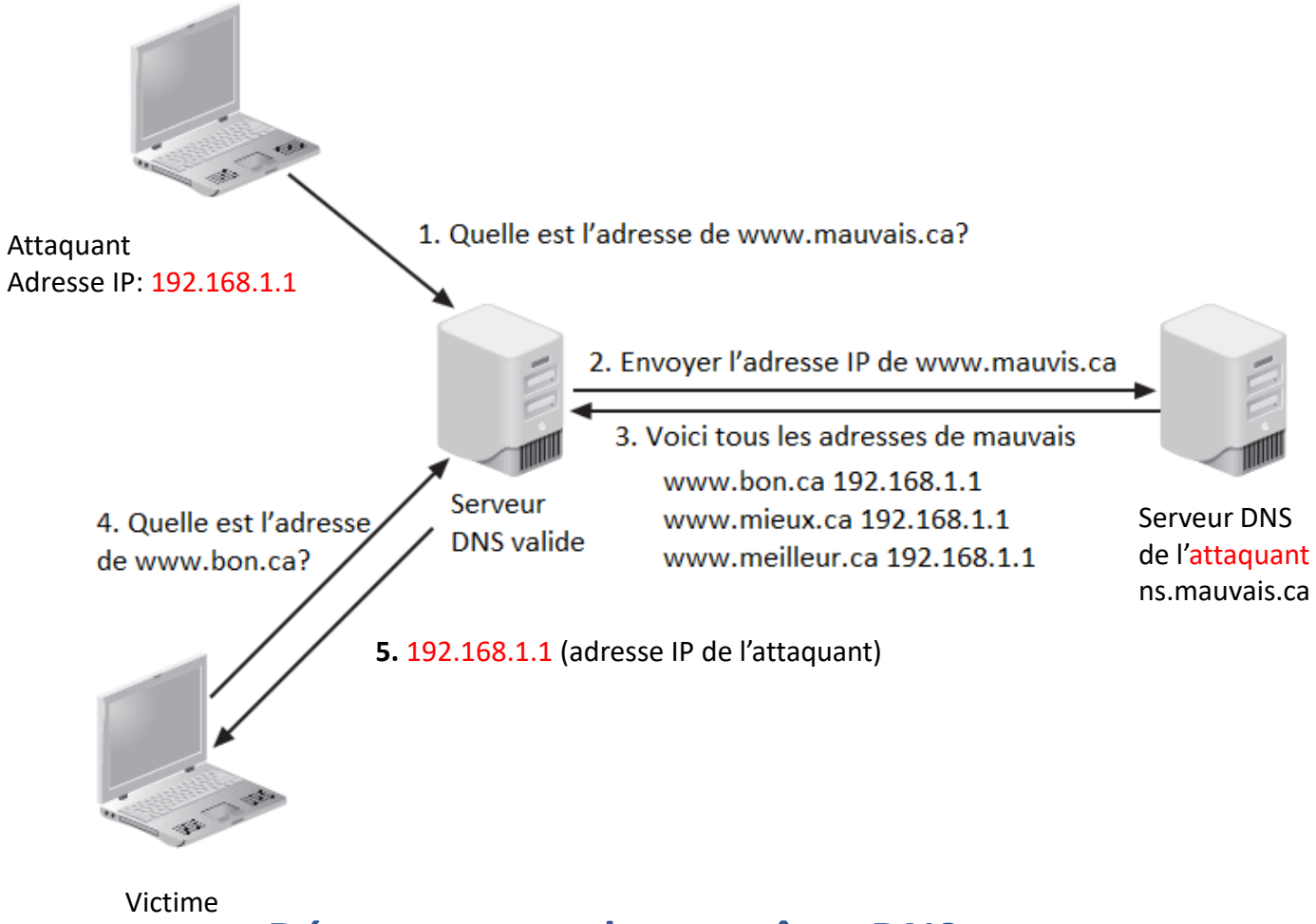
Attaques par ingénierie sociale (suite)

- Attaques de type trou d'arrosage (*watering hole*)
  - Repose à la fois sur l'exploitation de failles informatiques et l'utilisation de l'ingénierie sociale
    - S'introduire dans l'un des sites Web ou services utilisés par les employés d'une entreprise et y insérer un code malveillant à télécharger (cibler l'entreprise par ses adresses IP)
    - Une fois le contenu malveillant téléchargé par un employé, s'attaquer aux infrastructures de l'entreprise ou récupérer des informations renvoyées par le code malveillant
- L'aide de la voix sur IP (VoIP)
  - Appeler un employé en affichant un numéro interne de l'entreprise
  - L'employé victime sera donc plus enclin à donner des renseignements sensibles

Attaques par ingénierie sociale (suite)

- **Attaque par réinitialisation du mot de passe**
  - Solliciter le service en ligne pour demander la réinitialisation du mot de passe d'un compte
    - Détenir des informations personnelles sur le détenteur du compte
    - Intercepter le courriel de réinitialisation si on contrôle le compte de secours ➔ **le niveau de sécurité du compte est celui du maillon le plus faible**
    - Créer un message (courriel ou SMS) qui renverra la victime à une page de réinitialisation contrefaite (hameçonnage ou *phishing*)
- **Attaque par usurpation d'identité informatique**
  - Tromper directement les utilisateurs: hameçonnage (*phishing*)
    - Faire passer un site Web pour un autre
  - Tromper les logiciels et les procédures automatisées du système d'exploitation
    1. Générer de de vrais faux certificats numériques
    2. Détourner des requêtes DNS (*DNS poisoning*)

Attaques par ingénierie sociale (suite)



Détournement des requêtes DNS

Attaques par ingénierie sociale (suite)

- Spam
  - Courriels non sollicités
  - Peut être un véhicule pour la distribution de malwares
- Canulars (*hoaxes*)
  - Fausses alertes ou revendications
  - Peut constituer la première étape d'une attaque
- Fouille de poubelles (*Dumpster diving*)
  - Fouiller dans les poubelles pour trouver des informations utiles
- Talonnage (*Tailgating*)
- Regards indiscrets *(shoulder surfing)*
- *Deep fake*